

1. Introduction to Data Protection

Introduction to Data Protection

Objective: This section aims to help you understand the purpose of this training and the key concepts and types of personal data.

Outcome: Upon completion, you should be able to identify personal data and the key concepts of data protection.

1.1. Personal Data

Let's start with something simple: data is personal. Behind every email address, wallet ID, and login credential is a living, breathing human being, someone trusting us with pieces of their digital identity. And as with any kind of trust, once you break it, it's very difficult to earn back. Every time you store, share, or view customer data, you're not just managing numbers, you're managing someone's privacy and security.

Regulators often define personal data as any and all data about an identified or identifiable individual, such as full name, email address, postal address, phone number, images and video, online unique identifiers such as IP addresses. There is also sensitive personal data, such as medical/health data; racial or ethnic origin; political opinions; religious beliefs; trade union membership; sexual life or sexual orientation; genetic data or biometric data; citizenship or citizenship status.

However, what qualifies as personal data is broader than you think. Under some data protection frameworks, the concept of personal data is intentionally broad. It goes well beyond obvious identifiers such as names, phone numbers, or email addresses. Information like IP addresses, device identifiers, metadata, location data, wallet addresses, or public keys can also qualify as personal data where they can be linked to a real person using means that are reasonably likely to be used.

Here is the key takeaway: People love saying, "Don't worry, it's anonymized." That's like saying, "Don't worry, it's invisible until someone looks hard enough." We will discuss the concepts of anonymization and pseudonymization later in this training but for now what we want you to know is that truly anonymous data **is data that cannot be linked back to a person by any means reasonably likely to be used, whether directly, indirectly, or through correlation.** In practice, that standard is extremely hard to meet. Most data

described as “anonymized” is actually pseudonymized, the identifiers are masked or transformed, but the link to a real person still exists.

For example, a hashed wallet ID may look anonymous on its own. But once it is combined with transaction patterns, timestamps, or external datasets, re-identification can become possible. At that point, the data stops being anonymous. These are essentially ‘keys’ that unlock the original personal data by unmasking the person they are connected to. **The rule of thumb is simple:** if re-identification is realistically possible, treat the data as personal data. Regulators do. And for the individuals affected, “almost anonymous” still means their data, and their risk.

Why does all of this matter?

We operate in a regulated sector, and compliance with data protection and confidentiality rules is not optional; it is a legal and regulatory requirement. Failures can lead to regulatory sanctions, fines, contractual breaches, and reputational damage. But beyond the rules, this is also about trust and common sense. Every one of us has dozens of subscriptions, online accounts, and digital footprints. Think about how you would feel if another organization casually shared your data, even if it seemed “harmless” or “non-identifying” at the time. Protecting personal data means treating other people’s information with the same care and restraint you would expect for your own. That mindset is essential to maintaining trust with customers, partners, and colleagues, and to operating responsibly in a data-driven, highly interconnected environment.

Alright, let’s play a quick game called Spot the Personal Data and Sensitive Personal Data in the example below.

Imagine this: you are part of our customer support team and you received the following email.

“Hi there! My name is Sheldon Cooper, and I recently moved to 2311 North Los Robles Avenue, Pasadena, California. You can reach me at sheldon.cooper@bazinga.com or at my phone number 12340492. I’ve been struggling with access to my account since I have some medical issues, and I’m under treatment for high blood pressure. I am also a member of a local political group that advocates for environment policies for climate change. My wallet address is oxa54242s2, and I usually log in from my home internet connection. I recently made several crypto transactions using this wallet.

I wanted to check if my data are secure with you. Thanks!”

Can you spot the personal data and sensitive personal data in the interaction? Go back to the definitions in the previous paragraphs and see how many you can find.

The Golden Rule of Data

If you take nothing else from this training, remember this: Handle personal data the way you'd want your own data handled. In practice, this means being transparent about what data you collect, disciplined about why you collect it, and responsible in how you use and protect it. It comes down to permission, purpose, and protection; the three "P's" of responsible data handling

So before collecting or sharing any piece of personal information, ask yourself: *"Do I really need this? Do I have a lawful basis or permission to use it? Can I keep it secure?"* If the answer to any of these is "no" or "I'm not sure," stop and check first.

Data Protection Principles

Data protection principles are not abstract legal theory or box-ticking exercises. Just because we can collect, store, analyze, or share data does not mean we should. The principles require us to slow down and justify our actions: why we are collecting data, how long we keep it, who can access it, and what happens if something goes wrong.

In a regulated environment, these principles are how regulators judge behavior, not intentions. When things go wrong, the question is rarely *"Did you mean well?"* It is *"Did you follow the principles?"* Understanding them is what separates responsible data handling from accidental misuse, and compliance from costly mistakes.

Alright, let's discuss each of those principles briefly:

1. Lawful, Fair, and Transparent Processing: It's very self-explanatory: we must collect and process personal data lawfully, fairly, and transparently. You're probably thinking "that doesn't actually explain anything." Fair point. Let's break it down:

- **Lawful:** We must have a valid legal basis to process data, such as consent, a contract, a legal obligation, or a legitimate interest.
- **Fair:** Processing must not be misleading or unjust. Data subjects should know how and why their data is being used, and it must be in line with their expectations.

- **Transparent:** We must provide clear, accessible information to data subjects about how their data will be processed. This includes details on purpose, data retention, and their rights under the law.

2. Accuracy & Data Minimization: This principle means that personal data must be accurate, kept up to date, and limited to what is necessary for the intended purpose. That means:

- Personal data must be accurate and kept up to date. If we hold outdated or incorrect information, it can lead to poor decision-making or harm to the individual. For example, if a customer's contact details change, we should update our records based on reliable information or the customer's instructions, and not make assumptions or unauthorized changes. Accuracy means correcting errors responsibly, not guessing.
- We should only collect the minimum amount of data required to fulfill the specific purpose. If we're collecting more than we need, we're not complying with this principle.

3. Purpose Limitation: This principle means that personal data may only be collected for specific and legitimate purposes and not reused in a way that is incompatible with those purposes. That means once data is collected for a specific purpose, it can't be repurposed for something unrelated. If you initially collect data for customer service, don't start using it for targeted advertising without additional consent from the data subjects.

4. Storage Limitation: This principle means that personal data must not be kept for longer than necessary to meet its original purpose or legal obligations. Therefore:

- Data should only be stored as long as it's needed to achieve the purpose it was collected for, whether that's completing a transaction, providing a service, or complying with a legal requirement.
- In some cases, the law requires data to be kept for a specific period (e.g., financial records for tax purposes). However, once the data is no longer needed for these reasons, it should be securely deleted or anonymized.

PLEASE NOTE: We currently have a litigation hold in place. This means that we must not delete, alter, overwrite, or destroy any information that may be relevant to the matter covered by the hold. This applies regardless of normal data retention or deletion practices and includes emails, messages, documents, files, system records, and any other related data.

For more information, or if you are unsure whether certain data is covered by the litigation hold, please reach out to our General Counsel.

5. Security, Integrity, & Confidentiality of Personal Data: This principle means that appropriate technical and organizational measures must be in place to protect personal data from unauthorized access, loss, damage, or misuse.

6. Accountability & Data Subject Rights: This principle means that the Company must comply with data protection laws and support individuals in exercising their legal rights over their data. In practice, if someone asks what data we hold on them, wants it corrected, or asks us to stop using it, we don't ignore the request or treat it as a nuisance. We respond clearly, on time, and in line with our legal and regulatory obligations. However, please note that we have a dedicated team that responds to such inquiries. So, if you receive such a request, please forward it to our legal team and they will handle it.

7. International Data Transfers: This principle means that personal data may only be transferred internationally where the applicable laws or regulations allow it and appropriate safeguards are in place. **Simply put**, personal data can only be transferred internationally if there's a legal mechanism in place, such as an adequacy decision from the relevant authorities or appropriate contractual safeguards such as including relevant data protection clauses to new agreements or amending existing agreements via an addendum. Also, when transferring data internationally, we must ensure that the destination country or organization has adequate protection measures to ensure the security and privacy of the data. Where necessary, this can be conducted via a transfer impact assessment.

1.2. Common Mistakes & How to Avoid Them

Alright, now that we've covered the key concepts, it's time to talk about where things usually go wrong. And to be honest, that's the purpose of this training.

What follows are some of the most common data protection examples and mistakes we see in practice, along with simple ways to avoid them, so you don't have to learn the hard way, or star in our future "what not to do" example. You will be the next Joe.

Collecting More Data Than Necessary

- **The mistake:** Asking for or storing extra information “just in case” it might be useful later.
- **Why it’s a problem:** Excess data increases regulatory exposure and breach risk without adding value.
- **How to avoid it:** Before collecting data, ask what decision or obligation it actually supports. If there’s no clear answer, don’t collect it.

Treating “Internal” Data as Low Risk

- **The mistake:** Assuming that data is safer or less regulated because it stays within the company.
- **Why it’s a problem:** Internal misuse and accidental disclosure are among the most common causes of data incidents.
- **How to avoid it:** Apply the same care and access controls internally as you would with customer-facing data.

Assuming Data Is Anonymous When It Isn’t

- **The mistake:** We covered this one already above. Labeling data as “anonymized” because names or obvious identifiers are removed.
- **Why it’s a problem:** If data can be linked back to a person, directly or indirectly, it may still be personal data under most regulatory frameworks.
- **How to avoid it:** Assume data is personal unless you are confident re-identification is not reasonably possible. When in doubt, treat it as personal data. Or just ask Compliance, we don’t bite.

Reusing Data for New Purposes Without Reassessment

- **The mistake:** Using existing data for a new project, analysis, or product without checking whether the original purpose still applies.
- **Why it’s a problem:** Purpose limitation is a core regulatory principle, especially in financial services where profiling and analytics are closely scrutinized.
- **How to avoid it:** New purpose equals new review. Stop, reassess, and confirm that the use is permitted before proceeding.

Sharing Data Too Freely with Third Parties

- **The mistake:** This one is big. Sending personal data to vendors, partners, or service providers without checking protections or agreements.
- **Why it's a problem:** We remain accountable for the data, even when someone else processes it on our behalf. Third party vendor breaches trigger the same regulatory obligations as internal breaches.
- **How to avoid it:** Confirm that appropriate data protection agreements are in place with legal and compliance and that the third party is authorized before sharing anything.

Underestimating Email, Messaging, & Collaboration Tools

- **The mistake:** Treating emails, chats, and shared documents as informal or low-risk.
- **Why it's a problem:** These tools are frequent sources of accidental disclosure, especially when they contain financial or personal data.
- **How to avoid it:** Pause before sending. Check recipients. Avoid oversharing. Assume messages may be reviewed later, because sometimes they are.

Failing to Escalate Uncertainty

- **The mistake:** Proceeding despite doubts because stopping feels inconvenient or slow.
- **Why it's a problem:** We expect escalation, not improvisation. Silence is rarely a defensible decision.
- **How to avoid it:** If something feels unclear, unusual, or uncomfortable, pause and ask. Early questions prevent late-stage problems. Seriously by now you should have our reporting procedures and expectations firmly committed to memory. If not, we may need to schedule a very serious (but friendly) refresher conversation.

Finally

Data protection failures rarely come from a single big mistake. They come from small, everyday decisions made without thinking through the consequences. This section exists to help you recognize those moments, and choose the safer path before they become an issue for you, the company, or our customers.

1.3. Illustrative Examples

The examples provided aim to offer you a broad understanding of scenarios that could lead to a data privacy incident. However, this list is not exhaustive. If you have any

questions or concerns, please contact your direct report or any Key Stakeholder for guidance.

Joe, a customer support specialist, receives an urgent email that appears to come from the company's CFO. The message explains that there is a critical issue and requests immediate access to customer transaction logs. It includes a link for Joe to log in and upload the data.

The email looks legitimate: it uses the company logo, a familiar tone, and a realistic email signature. Feeling the pressure to act quickly, Joe clicks the link and enters his login credentials. The page refreshes and displays "Session expired."

Confused, Joe tries again. By then, his credentials have already been captured, and the attacker has access to internal systems and customer data.

Why It's a Privacy Lesson

- As we have learned from our incredible Cybersecurity team and their training, phishing attacks often rely on urgency and authority to bypass good judgment.
- Compromised credentials can lead to unauthorized access to personal and financial data, triggering a reportable data breach.
- Even a single mistake can result in regulatory scrutiny, fines, mandatory notifications, operational disruption, and reputational damage.
- When something feels urgent and unusual, that is exactly when you should slow down.

What to Do Instead

- Again, as we have been instructed by our Cybersecurity team, never enter credentials via links in unexpected emails.
- Verify unusual requests through a separate, trusted channel.
- Report suspected phishing immediately to Cybersecurity, who will coordinate with Compliance as needed.

Joe leaves the company on poor terms. Due to a breakdown in offboarding controls, his system access is not revoked immediately. Before his access is removed, he downloads a large volume of customer data onto a personal storage device.

Weeks later, customer data appears for sale online. An internal investigation confirms the data originated from Joe's account. The incident results in regulatory investigation, mandatory notifications, and significant reputational harm.

Joe faces criminal consequences for unauthorized access and disclosure of personal data. Separately, regulators scrutinize the company's access controls and offboarding procedures.

Why It's a Privacy Lesson

- Access to personal data must be strictly limited and promptly revoked when roles change or employment ends.
- **Downloading company or customer data to personal devices is prohibited.**
- Insider threats are a known regulatory risk, even when actions are malicious and unauthorized.
- Criminal liability for individuals and regulatory consequences for companies are separate issues, but both are real.

What to Do Instead

- Never copy or store company data on personal devices.
- Ensure access is removed immediately upon termination or role change.
- Report any access issues or concerns to Legal and Compliance without delay.

The company maintains strong internal security controls but relies on a third-party payment processor for certain transactions. That processor suffers a cyberattack, exposing customers' bank details and KYC information.

Although the breach occurred at the vendor, customers associate the failure with the company. Complaints surge, accounts are closed, and regulators demand explanations.

Why It's a Privacy Lesson

- Companies remain accountable for personal data even when it is processed by third parties.

- Vendor failures can create the same regulatory and reputational impact as internal breaches.
- Regulators expect robust third-party risk management, not blind reliance on vendors.

What to Do Instead

- Always involve Legal, Compliance, and Cybersecurity before engaging new vendors or tools. Remember, we have a new [Outsourcing & Procurement Procedure](#).
- Check with Legal to ensure contracts include clear data protection and breach notification obligations.
- Check with Compliance to assess the vendor data handling early.

To Summarize, here are your key takeaways:

1. Most serious data incidents start with small, avoidable decisions.
2. Early reporting reduces harm; silence makes everything worse.
3. Honest mistakes, when reported promptly, are handled very differently from concealment or delay.
4. Legal and Compliance are always the first point of contact for data breaches or suspected breaches.
5. The whistleblowing channel is reserved for situations where someone else failed to report or attempted to hide an issue.

1.4. Your Obligations When Handling Personal Data

Handling personal data is not abstract or theoretical; it is a personal responsibility that comes with legal, regulatory, and professional consequences. Every interaction with data matters. Every access, share, or storage decision increases or reduces risk.

Access Data Only on a “Need to Know” Basis

You are obligated to access personal data only when it is necessary to perform your job. Access is granted based on role, not entitlement. Think of it like working in a secured facility: being inside the building does not give you access to every room. The same applies to data systems.

Share Data Only When Necessary and Only the Right Way

Do not share personal data externally unless you get Compliance and Legal's approval. As simple as that. Also, and very importantly, when sharing data, you must:

- Use the approved and secure channels.
- Limit visibility. Share the minimum amount required, nothing extra.
- Verify recipients carefully. One wrong address can create a reportable incident.
- Keep work data in work systems. Personal email, messaging apps, or storage accounts are not acceptable.

Here is a simple test: If you would struggle to explain your data-sharing decision to compliance or the relevant regulator, you should not proceed.

Handle & Store Data with Care

You are obligated to protect personal data against loss, misuse, or unauthorized access. When working with data:

- Store it only in approved company systems.
- Never upload personal data into third-party tools unless they are formally approved.
- Do not save files locally unless permitted.
- Lock your screen when stepping away. We covered remote employment risks in our Code of Ethics. Make sure to review those.
- Avoid printing unless absolutely necessary, and dispose of printouts securely. Use a paper shredder for documents you no longer need; never use a standard trash can for sensitive info.
- Clean desk policy: clear your workspace of all sensitive information and clutter at the end of each workday. When working from places that are accessible by other people (i.e. company's premises, shared workspaces, hotels, etc. remove all papers, notes, printouts, notebooks from the desk. Place sensitive documents in a locked drawer, safe or filing cabinet.
- If existing tools are insufficient, raise the issue. Do not work around it.

Security failures often come from routine behavior. Treat every dataset as something that deserves care and control.